NEXUS GAP ANALYSIS TASK

Governance, Risk and Compliance (GRC)

Analyst: Maureen Uzoewulu

August 22, 2026

Table of Contents

Case Study: Nexus Financial Services 3

Company Introduction 3

Executive Summary 4

Security Gaps, Controls and Recommendations 6

ISMS Scope Definition 8

Current PDCA Stages 9

Remediation priorities 11

Conclusion 13

References 14

Case Study: Nexus Financial Services

Company Introduction

You have been engaged as a GRC Analyst to perform an ISO 27001 gap analysis for a company called Nexus Financial Services. The company operates three key business areas:

- IT & Operations - Manage infrastructure, cloud hosting and data centres.
- Finance & Compliance - Handles customer data, transactions and regulatory reporting.
- Human Resources - Manages employee records and third-party contractor data.

Nexus is preparing for ISO 27001 certification and needs you to identify gaps, prioritize remediation and produce a readiness report.

ISMS Scope

- 250 employees across 3 offices
- Cloud-hosted customer data (AWS)
- Payment processing systems
- Mobile banking application
- Third-party API integration
- On-premises Active Directory

Current challenges

1. No formal ISMS governance
2. Policies/objectives/risks processes not established
3. Departments implement controls independently
4. Critical assets not fully identified/classified
5. Limited risk visibility

Business Impact

1. Increased data breach risk
2. Potential regulatory exposure
3. Inconsistent control protection
4. Reduced customer/stakeholder confidence
5. Certification delays
6. Higher operational and compliance risk

Task:

1) Identify 5 security gaps
2) Map each gap to an Annex A category/control
3) Recommend one control per gap
4) Define the ISMS scope in 1-2 sentences
5) Identify the Current PDCA Stages
6) Prioritize remediation

Executive Summary

This ISO/IEC 27001 gap analysis assesses Nexus Financial Services' readiness for information security certification across its IT & Operations, Finance & Compliance, and Human Resources functions. The proposed ISMS scope covers 250 employees across three offices and includes AWS-hosted customer information, payment-processing systems, the mobile-banking application, third-party API integrations, on-premises Active Directory, and the related employee, contractor, customer, transaction, and regulatory-reporting data.

The assessment finds that Nexus has significant operational security exposure because it lacks the formal management-system foundation required for ISO 27001 certification. Although departments may already apply some security controls independently, Nexus lacks a centralized ISMS governance structure, documented information-security objectives, an organization-wide risk-assessment and treatment process, a complete inventory and classification of critical assets, or consistent access and supplier-risk controls. This fragmented approach creates inconsistent protection of sensitive information and limits management's ability to understand, prioritize, and demonstrate treatment of security risks.

Five major gaps were identified:

1. Lack of formal ISMS governance, policy, accountability, and management oversight.
2. Absence of a consistent information-security risk assessment and risk-treatment process.
3. Incomplete identification, ownership, and classification of critical information assets.
4. Inconsistent identity, access-control, and privileged-access practices across departments and systems.
5. Insufficient governance of cloud, third-party supplier, and API-integration risks.

These gaps matter because Nexus processes high-value financial and personal information through cloud infrastructure, payment systems, mobile banking services, and third-party connections. If not addressed, they increase the likelihood of data breaches,

unauthorized access, service disruption, regulatory non-compliance, financial loss, customer distrust, and delays in ISO 27001 certification.

Nexus is currently in the early stages of the ISO 27001 continual-improvement lifecycle. Its *Plan* stage is largely undeveloped because it has not formally established policy, scope governance, objectives, risk criteria, asset ownership, or treatment planning. Its *Do* stage is fragmented because individual departments implement controls without a consistent enterprise framework. The *Check* and *Act* stages appear mostly absent because there is no clear evidence of standardized control monitoring, internal audit, management review, corrective action, or continual-improvement processes.

The highest remediation priority is to establish the ISMS foundation: obtain senior-management sponsorship, define ISMS roles and responsibilities, approve the ISMS scope and information-security policy, implement a risk methodology and central risk register, and develop a Statement of Applicability. Nexus should then complete its asset inventory and classification program, standardize identity and access management, and implement formal cloud, supplier, and API security governance. Finally, it should introduce performance metrics, security monitoring, staff awareness training, internal audits, management reviews, and corrective-action processes.

Security Gaps, Controls and Recommendations

Identified Gap	ISO/IEC 27001:2022 Annex A category/control	Priority	Recommendation	Rationale
No formal ISMS governance, security policy, defined ownership, or executive oversight	**Organizational controls:** A.5.1 Policies for information security; A.5.2 Information security roles and responsibilities	Critical	Establish an ISMS governance structure approved by senior management: appoint an ISMS owner, define security roles and decision rights, create an information-security policy, and institute a recurring ISMS steering committee.	Without accountable governance, departments implement security inconsistently, and Nexus cannot demonstrate leadership, policy approval, ownership, or continual improvement.
No formal, consistent information-security risk assessment or risk-treatment process	**Organizational controls:** A.5.7 Threat intelligence; also supported by ISO 27001 clauses 6.1.2 and 6.1.3	Critical	Implement a documented risk-management methodology that defines risk criteria, risk owners, likelihood/impact ratings, acceptance thresholds, treatment options, residual-risk approvals, and review intervals. Maintain a centralized risk register.	Nexus has "limited risk visibility," so it cannot show that it has identified and treated risks to customer data, payments, cloud services, mobile banking, or third-party APIs.
Critical information assets are not fully	**Organizational controls:** A.5.9	High	Create and maintain a centralized asset register covering data sets,	An incomplete inventory means Nexus may not know

identified, assigned owners, or classified	Inventory of information and other associated assets; A.5.12 Classification of information		applications, AWS resources, payment platforms, API connections, endpoints, Active Directory components, and suppliers. Assign an owner and classification to every critical asset.	where sensitive customer and financial data resides, who owns it, or which systems require the strongest safeguards.
Access controls are implemented independently, creating inconsistent identity, privileged-access, and access-review practices	**Organizational controls:** A.5.15 Access control, A.5.16 Identity management, A.5.18 Access rights; **Technological controls:** A.8.2 Privileged access rights, A.8.5 Secure authentication	High	Establish a centralized access-control standard with role-based access control, MFA for AWS, payment systems, mobile-banking administration, and remote access; require joiner-mover-leaver workflows and quarterly access reviews for privileged and sensitive roles.	Inconsistent access practices increase the likelihood of unauthorized access to customer records, payment transactions, employee data, AWS environments, and Active Directory.
Third-party/cloud and API security risks are not centrally governed or monitored	**Organizational controls:** A.5.19 Information security in supplier relationships; A.5.20 Addressing	High	Implement a third-party risk-management process that requires security due diligence, risk ratings, contractual security clauses, incident-notification requirements, annual reviews, and documented	Nexus depends on AWS and third-party API integrations. A supplier or API weakness can expose customer data, interrupt payments, create

	information security within supplier agreements; A.5.23 Information security for use of cloud services		AWS/cloud shared-responsibility requirements.	regulatory exposure, and reduce customer confidence.

ISMS Scope Definition

The ISMS should cover the people, processes, information, applications, infrastructure, and third parties supporting Nexus Financial Services' IT & Operations, Finance & Compliance, and Human Resources functions across its three offices. This includes AWS-hosted customer data, payment-processing systems, the mobile-banking application, third-party API integrations, on-premises Active Directory, and data handled by employees and contractors. The scope should explicitly include customer, transaction, employee, contractor, security, operational, and regulatory-reporting information, along with the interfaces between Nexus and its cloud, payment, and API suppliers.

Current PDCA Stages

ISO 27001 uses a continual-improvement management approach that can be understood through **Plan–Do–Check–Act (PDCA)**. Nexus appears to be predominantly at the early **Plan** stage, with inconsistent **Do** activities occurring independently across departments.

PDCA Stage	Nexus' Current State	Evidence	Gap Implication
Plan	Immature	No formal ISMS governance; policies, objectives, and risk processes are not established; incomplete asset identification and classification.	Nexus lacks a defined ISMS foundation, risk methodology, objectives, scope governance, and controlled remediation plan.
Do	Fragmented	Departments implement controls independently; AWS hosting, payment processing, mobile banking, Active Directory, and API integration exist operationally.	Controls may exist, but they are not necessarily risk-based, standardized, documented, owned, or demonstrably effective.
Check	Missing	Limited risk visibility; no indication of metrics, monitoring, internal audit,	Nexus cannot reliably measure ISMS effectiveness or prove control performance to certification auditors.

		control testing, access reviews, or management review.	
Act	Missing	No formal ISMS or structured risk process is described.	No formal corrective-action process, lessons-learned cycle, or management-led continual-improvement mechanism is described.

Remediation priorities

Phase 1: Build the ISMS foundation – Immediate

These should be completed first because they enable every later control and create the evidence base for certification:

1. Obtain executive sponsorship and formally appoint an ISMS manager, risk owners, asset owners, and control owners.
2. Approve the ISMS scope, information-security policy, governance charter, and reporting structure.
3. Establish the information security risk assessment and risk treatment methodology.
4. Develop a risk register covering AWS, payment processing, mobile banking, APIs, Active Directory, customer data, employee data, and regulatory reporting.
5. Produce a Statement of Applicability (SoA) that identifies applicable Annex A controls, implementation status, justification for inclusion, and rationale for exclusions.

Goal: To demonstrate that Nexus can show that security decisions are governed, risk-based, owned, documented, and approved.

Phase 2: Protect critical information and systems – High priority

1. Complete the enterprise asset inventory and information-classification scheme.
2. Identify owners for customer, transaction, employee, contractor, payment, and application data.
3. Centralize identity and access management standards, including MFA, least privilege, role-based access, privileged-access restrictions, and periodic access reviews.
4. Formalize cloud and third-party controls for AWS, payment processors, and API providers.
5. Establish incident-management procedures, escalation paths, evidence collection requirements, and incident exercises.

Goal: Nexus knows what it must protect, where it resides, who is responsible, and how it controls access and supplier risks.

Phase 3: Demonstrate and improve effectiveness – Certification readiness

1. Define security objectives and measurable KPIs, such as completion of access reviews, vulnerability-remediation timelines, backup-recovery test success rates, incident-response exercise results, and supplier-review completion.
2. Establish monitoring, logging, vulnerability management, backup testing, and security-event reporting.
3. Conduct awareness training for employees and contractors, focused on customer data, phishing, passwords/MFA, acceptable use, remote work, and incident reporting.
4. Perform internal audits against clauses 4–10 and the selected Annex A controls.
5. Conduct management review, record decisions and corrective actions, remediate nonconformities, and repeat the assessment before certification.

Goal: Nexus moves from designing controls to proving that controls operate effectively and are continually improved.

Conclusion

Nexus has a meaningful operational technology footprint, but the existing security approach is decentralized and insufficiently governed for certification. The immediate goal should not be to implement every Annex A control identically; instead, Nexus should first establish a defensible ISMS, identify and assess its risks, determine applicable controls, document the Statement of Applicability, and then implement and test prioritized safeguards. By following a phased, risk-based remediation approach, Nexus can move from fragmented departmental controls to a coordinated, measurable, and continually improving security management system. This will reduce data-breach and regulatory risks, improve protection of critical business systems and information, increase customer and stakeholder confidence, and place Nexus in a stronger position to achieve the ISO/IEC 27001:2022 certification.

References

1. International Organization for Standardization & International Electrotechnical Commission. (2022). *ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection—Information security management systems—Requirements* (3rd ed.). ISO.ISO_IEC_27001_2022-en-2-1.pdf
2. International Organization for Standardization & International Electrotechnical Commission. (2022). *ISO/IEC 27001:2022 gap analysis / ISO 27001 implementation material* [Course presentation]. *IEC 27001 (July '26)_Phoenix*.